Security audit — Nhill 3.0.0

Français : ../fr/03-audit-securite.md

> **Date:** 28 October 2026 · **Nature:** code and configuration review (“white box”), automated tests run, operating tools tried on a fresh Ubuntu 24.04 machine in continuous integration, dependencies checked against public vulnerability databases. **This is not a penetration test** and no claim of absence of vulnerabilities is made. The previous audit (0.1.0 → 2.0.0, 26 October 2026) is summarised in § 6.

1. Summary

The security model remains that of version 2: the server decides everything (roles, plan, subscription), each business is isolated by PostgreSQL row-level security enforced by the database, passwords are stored as Argon2id fingerprints, tokens are opaque, short-lived and rotating, platform administration requires two-factor authentication, backups are encrypted.

Version 3.0.0 adds new surfaces (plans and rights, console billing, payment providers, point of sale, full export, business erasure, virtual private server tools, marketing website and its forms). They were reviewed; four gaps were fixed during the audit (§ 3) and two risks remain open with a decision to take (§ 4, R1 and R2).

#	Risk	Severity	3.0.0 status
R1	**cpp-httplib 0.14.3** (Ubuntu 24.04 package): CVE-2025-46728 and CVE-2025-53629, unbounded memory with chunked request bodies; fixes published only through Ubuntu Pro (ESM)	High	**Open, mitigated**: the server listens on 127.0.0.1; Caddy refuses bodies over 6 MB before the server. Proposed fix: build against cpp-httplib ≥ 0.23 (single header). **Decision required** (§ 4)
R2	**Qt 6.5.3** bundled in the Windows installers and the Android APK (advisories published after 6.5.3, in particular HTTP/2: CVE-2023-51714, CVE-2024-39936)	High	**Mitigated in 3.0.0**: HTTP/2 disabled in the client (HTTP/1.1 only). Full fix: a maintained Qt version; impact on the minimum Android version to assess. **Decision required**
R3	Minimum password length: 8 characters (owner’s requirement)	Medium	Accepted risk, compensated (§ 5)
R4	Daily backup only: up to 24 hours of data lost if the server is lost	Medium	Open — continuous archiving of transaction logs (WAL) recommended
R5	`nhill.online` e-mail not set up (no MX, SPF or DMARC): address spoofing made easier, automatic messages undeliverable	Medium	Open — DNS setup by the operator
R6	Android file provider declared over the whole private storage of the application	Low	Accepted: provider not exported, access granted file by file by the application
R7	No external audit or penetration test	—	Open — before a broad commercial launch

2. Scope and threat model

- **Assets:** businesses’ commercial data, accounts and sessions, secrets (`NH_SECRET_KEY`, provider and webhook secrets, database credentials), backup private key, activity log, requests received by the website.
- **Actors considered:** anonymous Internet user; user of another business; employee with limited rights (cashier, sales); former employee; holder of a business code; console administrator with limited rights (support, billing, auditor); network attacker; spoofed payment provider; bot targeting the website forms.

- **Out of scope:** compromise of the user's device or of the host, physical attacks, volumetric denial of service.

3. Controls verified in 3.0.0

Area	Control	Evidence
Plans and rights	Each route declares its right; a function missing from the plan is refused by the server, not only hidden	`http/app.cpp`, `entitlements.cpp`; tests `Plans.*`
Access by subscription	Access computed by the database from the dates (full, read-only, none); writes refused in read-only, exports allowed	`nh_subscription_access` (`0012`); tests `Billing.*`
Console	Roles `superadmin`, `billing`, `support`, `auditor` checked per route; non-replayable TOTP two-factor authentication	`admin.cpp`, `console.cpp`; tests `Admin.*`, `Console.*`
Payments	Rights change only after a verified notification (signature, timestamp, amount) or a recording by the team; idempotent processing; provider secrets encrypted, never read back by the console	`subscriptions.cpp`, `providers.cpp`; tests `Webhook.*`, `Providers.*`
Point of sale	Supervisor approval: the supervisor's password, a person other than the requester, single-use token bound to the action, the requester and the session, valid 3 minutes; attempts limited; refusals logged	`pos.cpp` (`consumeApproval`, `/pos/approvals`); tests `Pos.*`
Blind close	The expected amount is never returned before the close; closed session immutable	`pos.cpp`, `nh_guard_pos_session`
Full export	Account holder only, 3 exports per 15 minutes, no password, token or code in the archive	`export.cpp`
Business erasure	Superadministrator only, trade name to type, never with full access; the application role cannot use the erasure flag (the triggers require the owner role)	`0014_establishment_erasure.sql`, `admin.cpp`; 6 tests `Erasure.*`, `Retention.*`
Retention	Sent messages deleted after 30 days, ended sessions after 90 days, server logs 90 days	`jobs.cpp`, `deploy/vps/provision.sh`; test `Retention.*`
Search	`%` and `_` typed by users are taken literally (escaped `LIKE` patterns)	`0015_search_patterns.sql`; test `Search.*`
Virtual private server	Database and API listening on 127.0.0.1 only; firewall active; secret files in 0600; no temporary superuser left; backup private key absent from the server; HTTPS with HSTS and HTTP redirect	`deploy/vps/tests/acceptance.sh`: **12 checks passed** on a fresh machine (CI `vps-test`, 28/10/2026)
Backups	`pg_dump` encrypted by `age` with no plain copy; trial restore on a throw-away instance, off the server, under an unprivileged account; isolation checked after restore	`nhill-backup.sh`, `nhill-restore-test.sh`; acceptance check 07
Update	Package checksum mandatory; backup and database copy beforehand; automatic way back; an older server refuses a database migrated by a newer version	`nhill-update.sh`, `nhill-rollback.sh`, `migrate.cpp`; acceptance checks 08 to 11, test `Setup.*`
Monitoring	Check every 5 minutes (service, database, HTTPS, certificate, ports, firewall, disk, backup) and alert	`nhill-healthcheck.sh`, `nhill-alert.sh`; acceptance check 06

Area	Control	Evidence
Marketing website	No cookie or external resource; content security policy without inline style or script; forms: allowed origins, JSON only, 16 KB maximum, honeypot field, minimum time, limits per address and per day, database role limited to inserting, IP fingerprint erased after 30 days	`website/backend`; 13 backend tests; `tools/check_site.py`
Client	HTTPS mandatory except local addresses; refresh token in the system keychain; **HTTP/2 disabled** (R2); Android: file provider not exported, per-file grant	`apiclient.cpp`, `session.cpp`, `AndroidManifest.xml`
Repository secrets	Pattern search (provider keys, private keys, tokens, `age` keys): no secret outside examples	automated search of 28/10/2026

Gaps found and fixed during the audit:

1. No deletion of a business's data existed, while the terms promise deletion 90 days after the end of the contract → migration 0014, console action, tests.
2. Automatic messages and ended sessions kept without limit (e-mail addresses, IP addresses) → daily deletion after 30 and 90 days.
3. `ILIKE` searches with unescaped `%` and `_` (risk S9 of the 2.0 audit) → fixed.
4. Backup checksum file tied to the server's directory: the check failed on an off-site copy → file name only, fingerprint comparison.

4. Decisions required

Risk	Recommended option	Effect
R1 cpp-httplib	Ship with the server a verified copy of cpp-httplib ≥ 0.23 (single header, MIT licence), version and fingerprint recorded, or use Ubuntu Pro's fixed packages	removes the vulnerability instead of mitigating it; to redo with each advisory
R2 Qt	Build Windows and Android with a maintained Qt version	removes the advisories published after 6.5.3; the minimum Android version may rise (check before changing the website)

5. Password policy (reminder of the 2.0 decision)

Minimum 8 characters (code points), no composition rule and no periodic change; common, repetitive or e-mail-equal passwords refused; attempts limited; Argon2id; other sessions closed on change. Two-factor authentication mandatory for the console, not imposed on businesses. For a password used alone, NIST SP 800-63B-4 recommends 15 characters: accepted risk (R3).

6. Follow-up of the 2.0.0 audit

2.0	Risk	Status in 3.0.0
S1	cpp-httplib 0.14	still open → R1
S2	Qt 6.4.2 bundled in the Debian 13 packages	fixed in 2.0 (native packages); Qt 6.5.3 of Windows and Android → R2
S3	No account recovery	fixed in 2.1 (e-mailed code, temporary password)
S4	8 characters	accepted risk → R3

2.0	Risk	Status in 3.0.0
S5	`X-Forwarded-For` read from the left	fixed in 2.0
S6	Personal data compliance	3.0.0 legal file (`legal/en/00-legal-research.md`); formalities to be completed by the operator
S7	No continuous WAL archiving	still open → R4
S8	No monitoring	fixed in 3.0 (checks every 5 minutes, alerts)
S9	Unescaped `ILIKE`	fixed in 3.0

7. Sources

- NVD — CVE-2025-46728: https://nvd.nist.gov/vuln/detail/CVE-2025-46728
- NVD — CVE-2025-53629: https://nvd.nist.gov/vuln/detail/CVE-2025-53629
- OSV — UBUNTU-CVE-2025-53629 (Ubuntu 24.04 cpp-httplib packages): https://osv.dev/vulnerability/UBUNTU-CVE-2025-53629
- Ubuntu — USN-7962-1, cpp-httplib (24.04 fixes through ESM): https://ubuntu.com/security/notices/USN-7962-1
- Debian Security Tracker — CVE-2024-39936 (Qt, HTTP/2): https://security-tracker.debian.org/tracker/CVE-2024-39936
- NVD — CVE-2023-51714 (Qt, HTTP/2 HPACK): https://nvd.nist.gov/vuln/detail/CVE-2023-51714
- NIST SP 800-63B-4: https://pages.nist.gov/800-63-4/sp800-63b.html